

# DMARC SCANNING

22BCY10242 - Nivedita Waghmare

22BCY10294 - Sanjana Lanka

22BCY10171 - Purigilla Akhila

22BCY10109 - Kiran Kumar Ch

22BCY10276 - Atharva Dnyaneshwar Shastrakar

# PROBLEM STATEMENT

**The Threat:** Email spoofing allows cybercriminals to impersonate legitimate domains, facilitating phishing attacks and eroding digital trust.

**The Core Issue:** Existing email authentication methods (SPF/DKIM) are ineffective without a unified policy framework. Domain owners lack both visibility into who is using their domain and control over how fraudulent emails are handled.

**The Impact:** This leads to significant brand reputation damage, financial losses from cyber incidents, and reduced deliverability for legitimate emails.

**Our Project's Focus:** To bridge this gap by systematically implementing DMARC, providing a clear blueprint for gaining visibility and enforcing security policies to protect a domain from unauthorized use.

# SCOPE: FOCUSED & MANAGEABLE

## In Scope (Our Focus):

- Single Domain: Implementation on one test domain we control.
- End-to-End Process: Full DMARC lifecycle (Audit → Monitor → Enforce).
- Core Protocols: Configuration of SPF, DKIM, and DMARC records.
- Data Analysis: Interpreting DMARC reports to measure effectiveness.

## Out of Scope (Boundaries):

- Multi-domain enterprise deployment.
- Custom software development.
- Long-term maintenance beyond the semester.

## Success Deliverables

- Enforced DMARC policy (p=reject) on test domain.
- Data report showing authentication results & impact.
- Documentation of the implementation process.

# SYSTEM ARCHITECTURE

## Architecture Overview

Our system acts as a DMARC analysis middleware, intercepting incoming emails to perform real-time authentication checks before they reach the end user. This design provides active protection and detailed visibility.

## Data Flow Explained

### Phase 1: Email Reception & Interception

- Component: Mail Server (Postfix)
- Action: Incoming email is intercepted or copied via a milter (mail filter), pipe, or API call.
- Purpose: This is the entry point where our system gets access to the email for analysis without blocking the main mail flow.

# SYSTEM ARCHITECTURE

## Phase 2: Real-Time DNS Authentication Check

- Component: DMARC Analysis Engine
- Action:
  - Extracts the sender's domain from the email headers.
  - Queries the DNS Server for that domain's SPF, DKIM, and DMARC records.
  - Performs the authentication checks (Does the IP match SPF? Is the DKIM signature valid?).
- Purpose: This is the core logic that determines the email's legitimacy.
- 

## Phase 3: Policy Enforcement & Action

- Decision Point: DMARC Check Pass?
- Pass: The email is deemed authentic. Instruction is sent to deliver to inbox.
- Fail: The email fails DMARC policy. Two actions are triggered:
  - Enforcement: Email is sent to spam/junk folder.
  - Alerting: The Alerting Module is triggered to send an immediate notification via email/API.

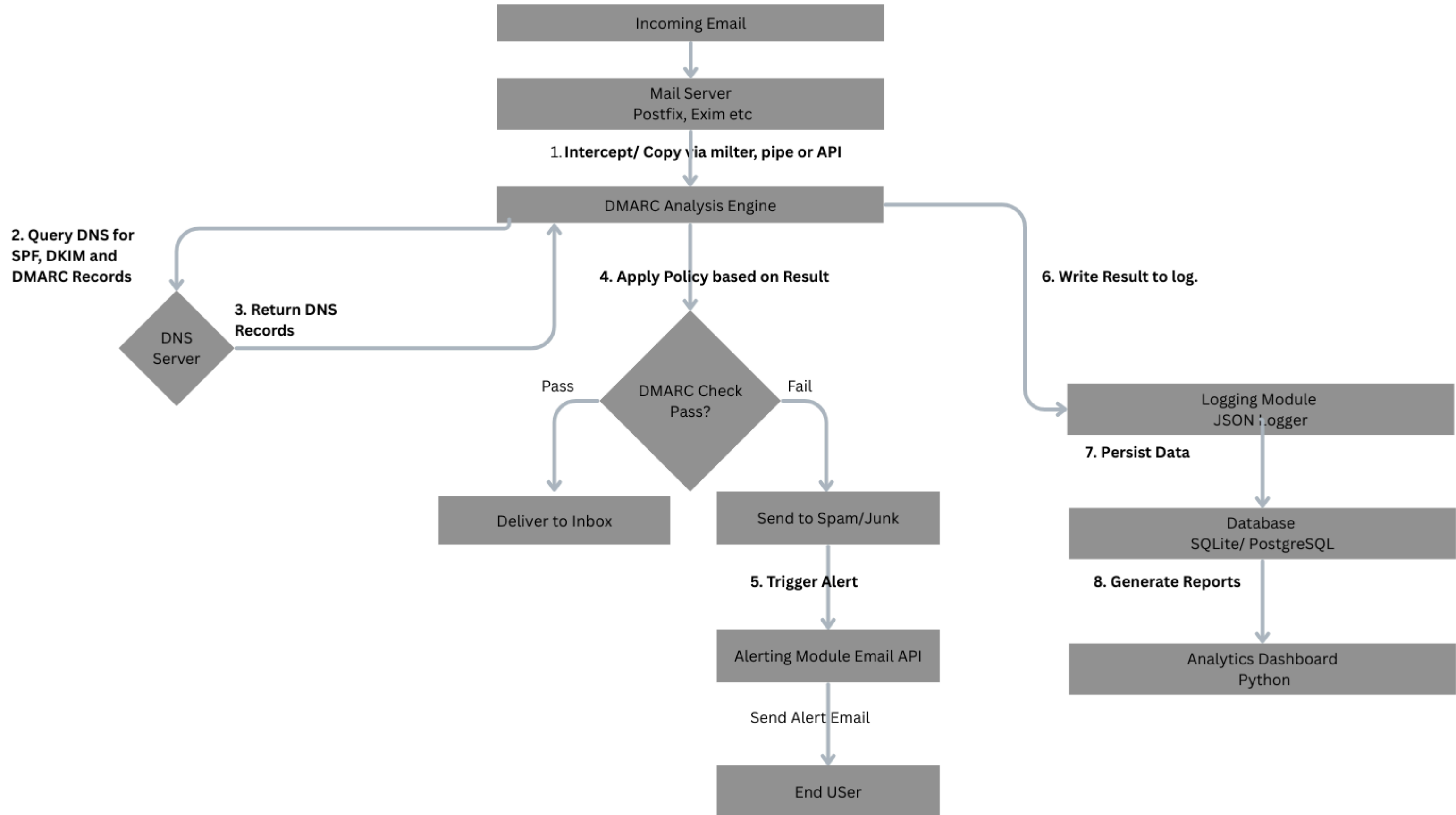
# SYSTEM ARCHITECTURE

## Phase 4: Logging, Storage & Analytics (Visibility)

- Component: Logging Module
- Action: The result of every check (pass/fail, reason) is written to a structured JSON log.
- Component: Database (SQLite/PostgreSQL)
- Action: Log data is persisted for long-term storage and analysis.
- Component: Analytics Dashboard (Python)
- Action: Generates comprehensive reports and visualizations from the stored data.

## Why This Prototype Demonstrates Quality

- Technical Depth: Shows understanding of key components: milters (Postfix), DNS queries, real-time decisioning, and data persistence.
- Proactive Approach: Goes beyond basic monitoring to include active enforcement (spam folder) and immediate alerting, which is an advanced feature.
- Foundation for Research: The logging and database setup is perfect for generating the data needed to analyze the effectiveness of DMARC policies—a key research goal.



# PROJECT TIMELINE

## Review 0

Completed

Project ideation, topic approval, initial research. Completed. Project concept finalized and approved.

## Review 1

Now. Proof of Planning. Detailed architecture, research, methodology, and initial setup. Deep planning phase. Architecture designed, research complete, beginning implementation.

## Review 2

Proof of Completion. Fully implemented solution, data analysis, final demo, and presentation.

**Goal.** DMARC fully enforced (project), results analyzed, and project documented.

# METHODOLOGY & APPROACH

## Our Three-Phase Methodology

We are following the industry-standard phased approach to ensure a safe and successful implementation.

### Phase 1: Audit & Preparation (Foundation)

- Objective: Identify all legitimate email sources.
- Actions:
  - Inventory all services sending email from our domain (e.g., website, marketing platform, CRM).
  - Verify and correct SPF records to include all authorized IPs.
  - Configure DKIM signing for all outgoing email streams.
- **Why this phase is critical:** Prevents "breaking" email delivery later by ensuring all good senders are properly authenticated from the start.

## **Phase 2: Monitor & Analyze (Visibility)**

- Objective: Gain visibility without impacting email flow.
- Actions:
  - Deploy DMARC record with a p=none policy and request aggregate reports (rua tag).
  - Collect and analyze reports from major email providers (Google, Microsoft, etc.).
  - Identify any unknown or failing email sources and rectify issues.
- Why this phase is low-risk: With p=none, no email is blocked. It's a "listen-only" mode that provides crucial data.

## **Phase 3: Gradual Enforcement (Protection)**

- Objective: Actively protect the domain from spoofing.
- Actions:
  - Step 1: Change policy to p=quarantine. Emails that fail DMARC are delivered to the spam folder.
  - Step 2: After confirming no legitimate email is being quarantined, change policy to p=reject. Emails that fail are blocked entirely.
- Why this phased enforcement is correct: It allows for careful testing. Quarantine acts as a final warning to catch any missed issues before moving to the strongest reject policy.

# METHODOLOGY & APPROACH

## Why This is the Correct, Low-Risk Approach

- Risk Mitigation: The gradual transition from monitoring to enforcement systematically eliminates the risk of blocking legitimate business email.
- Data-Driven Decisions: Each step is informed by data from the previous phase. We only enforce once we have verified our configuration is correct.
- Industry Best Practice: This methodology is recommended by cybersecurity bodies worldwide (e.g., CISA, NCSC) and used by major corporations.

**Conclusion:** This methodical approach ensures we build a secure email ecosystem methodically, without the disruptions that a rushed implementation would cause.

# DMARC Email Authentication Process

Step-by-step flowchart showing how emails are validated through DMARC protocol

